

한국서부발전(주) 상임감사위원 주 의(기관) · 권 고 · 개 선 요 구

제 목 전자결재시스템 구축 및 운영 관리 미흡
소 관 부 서 ㄱㄱㄱㄱ처 ㄴㄴㄴㄴ부, ㄷㄷㄷㄷㄷㄷ처 # # # # #부
조 치 부 서 ㄱㄱㄱㄱ처 ㄴㄴㄴㄴ부, ㄷㄷㄷㄷㄷㄷ처 # # # # #부
구 분 기록관리
내 용

1. 업무 개요

우리 회사에서 운영하는 ‘전자결재시스템’은 임직원이 회사의 업무와 관련하여 작성·시행·접수한 모든 기록물을 전자화하여 서버에 저장하고 사내 정보통신망을 통해 수시로 기록물을 열람하는 정보시스템의 일종이다. 회사의 임직원이 사용하는 정보시스템 중에서 ‘전자결재시스템’이 이용률이 가장 높으며 작성자의 필요에 따라 회사의 비밀, 개인정보 등을 포함할 수 있으며 각각의 문서 생성 시 문서의 기본 요소인 보존기간, 분류, 보존 방법, 접근 권한 등을 개인이 설정해야 하는 특성을 가지고 있다.

2. 관계규정 및 판단기준

「정보화규정」 제11조(시스템의 운영준비) 제2항에 따라 업무주관부서는 시스템 운영 개시일을 결정하기 전에 정보화주관부서와 협의하여 운영 제반사항을 점검 하여야 하고 제3항에 따라 정보화주관부서는 시스템 운영 개시일 결정 전에 위탁 용역업체와 협의하여 운영개시와 관련된 사항을 준비할 수 있도록 한다.



「문서 접근권한 책정 기준」 제9조에서는 기안자와 결재라인만 열람가능한 문서인 열람자제한³⁾, 해당 부서만 열람가능한 문서인 부서 제한, 해당 처실만 열람가능한 문서인 처실 제한으로 전체 공개를 하지 않는 문서에 대해 제한접근의 범위를 정하고 있다.

따라서 정보화주관부서는 정보시스템 운영 또는 구축 시 관련 규정을 준수 하며 맡은 바 업무에 소홀함이 없이 성실히 임해야 하고 문서관리부서는 전자결재 시스템의 문서 생성, 보관, 열람 상태를 주기적으로 점검하여 사내접근 권한 설정의 남용은 없는지 또는 접근 제한 문서의 비인가자 접근이 허용되어 비밀정보 등이 침해되는 사실은 없는지 등 전자결재 문서에 대한 관리를 철저히 하여야 한다.

3. 감사결과 확인

그런데 감사 결과 2023년 7월에 신규 구축한 전자결재시스템 문서작성 서식의 첨부파일 위치에 있는 ‘사내문서’라고 명명된 기능을 선택하는 경우, 새 창이 열리면서 제한접근 문서를 열람할 수 있도록 구현되어 권한이 없는 직원이 다수의 제한접근 문서를 열람한 사실이 확인되었다.

전자결재시스템은 회사의 중요한 의사결정, 감사, 보안, 개인정보, 인사, 내부신고, 민원 등의 다양한 종류의 정보를 담고 있는 정보시스템으로써 보안 취약점이 없도록 운용되어야 하며 최고 수준의 보안을 항상 유지하여야 마땅하다.

① 전자결재시스템 구축 시 기능 테스트 수행 및 과정의 기록관리 미흡

「정보화규정」 제11조(시스템의 운영준비)에 따라 정보화주관부서는 위탁용역 업체와 업무주관부서의 사이에서 요구사항을 전달하고 조율하는 역할을 이행하고

3) 열람자제한의 범위: 감사 관련 사항, 국가안전보장, 회사의 보안 등에 관한 사항, 개인의 사생활의 비밀 또는 자유를 침해할 우려가 있다고 인정하는 정보, 인사와 관련된 사항, 시험에 관련된 사항, 국민의 생명·신체 및 재산의 보호에 현저한 지장을 초래할 우려가 있는 정보, 내부신고자의 불이익이 예상되는 모든 정보



더불어 ‘최종 기능 테스트’ 시행 전에 ‘준공 전 기능 테스트’를 수행하는 역할을 성실히 이행하여야 한다.

또한 정보화주관부서는 업무주관부서에 개발 완료를 통보한 후에는 업무주관 부서가 다양한 실제 운영 환경에서 일반직원, 권한자, 검토자, 부서장 등 각각의 권한별로 접속하여 시스템 오픈 전 오류나 보안 취약점을 최소화할 수 있도록 하여야 하며 최종 점검 결과 이상이 없다고 판단되는 경우 시스템 구축을 완료 하여야 한다.

그러나 신규 전자결재시스템을 운영한 결과 직원들의 편의를 위하여 새롭게 구성된 ‘사내문서’ 첨부 기능에 대한 접근범위 설정 확인이 제대로 이루어지지 않아 제한접근 문서에 대한 비인가자의 차단을 허용하였고 이로써 일부 직원들이 다수의 열람자제한 문서를 권한 없이 열람하는 결과를 초래하였다.

또한 상기의 시험운영 과정에서 정보화주관부서와 업무주관부서는 회사의 중요 정보시스템을 구축하며 별도의 공문 또는 공식적인 절차의 진행 없이 업무 담당자간 구두로 의견을 통보하고 회신한 사실을 확인하였다.

정보화주관부서는 개발 완료 전에 업무주관부서로 공문을 통해 ‘준공 전 기능 테스트’ 결과의 통보 및 ‘최종 기능 테스트’ 수행을 요청하는 것이 절차상 바람직 하고, 업무주관부서 역시 ‘최종 기능 테스트’를 마친 후 테스트 결과를 공문으로 통보하는 것이 기능 테스트의 목적을 성실히 달성하는데 타당하다고 판단된다.

따라서 향후 회사의 중요 정보시스템 구축 및 보완개발 시 위와 같은 사례가 되풀이되지 않도록 하기 위한 자구적인 노력이 필요할 것으로 판단된다.

② 제한접근 문서 설정 및 열람에 대한 관리 강화 필요

사내문서 생성 시 문서생성자가 사내접근 기준을 바탕으로 개인적 판단에



따라 접근 범위를 설정하도록 하고 있으나 일부 직원들의 경우 자신의 휴가원, 유연근무제 신청 등을 개인정보로 인식하고 있으며 ‘사택운영 관리’ 문서, ‘연장 근무 한도 시간 알림’ 문서 등에 대하여 접근 범위를 과도하게 제한하는 경우도 확인되었다.

이는 오히려 공개되어야 공정성을 의심받지 않는 문서임에도 과도하게 열람자 제한을 설정하여 타인의 호기심 또는 갈등을 불러일으키도록 접근 범위를 설정하고 있는 것이며 사내접근기준에 근거하여 접근 범위가 설정될 수 있도록 시스템 개선 등의 관리 강화가 필요할 것으로 판단된다.

한편 「개인정보의 안전성 확보조치 기준」 제8조 2항에 따라 인사노무시스템에서는 다운로드 시 개인정보 이용 사유를 입력하게 되어 있는데 이를 활용하여 권한 보유와 상관없이 제한접근 문서를 열람하는 경우 내부감사, 공시 등 주요 사유를 선택 또는 입력하게 하여 업무주관부서가 제한접근 문서에 대한 관리 및 감독하도록 하고 열람 통계를 분석하는 기능을 구축하여 상시모니터링에 활용한다면 이번과 같은 행위를 조기에 발견할 수 있을 것이다.

이러한 1선 방어선의 개선 활동을 통해 ITAC⁴⁾(IT Application Control) 관점에서 열람 사유를 로그에 남겨 입력통제를 강화하고 추적 가능성을 확보하는 방식으로 위험을 낮추는 방안을 마련할 것을 권고한다.

관계부서(관련자) 의견 및 검토 결과

우우우우부, # # # # #부 업무 담당자는 감사 지적사항에 대해 이의가 없으며 명확한 업무처리를 위해 관련 규정을 개정하는 등 부서 상호간 협의를 통해 미흡한 점을 개선하겠다고 하였다.

4) 특정 어플리케이션의 트랜잭션 처리과정(입력, 처리, 출력)에서 데이터의 완전성, 정확성, 유효성, 적시성을 보장하기 위해 설계·구현된 통제활동



또한 사내문서 접근 범위의 설정부터 열람 기록까지 관리·감독을 강화하여
무분별한 제한접근 설정 방지, 무단 열람 등을 방지하도록 하겠다고 답변하였다.

조치할 사항

₩₩₩₩처장은 ① 사내문서의 과도한 접근 범위 설정 방지, 접근제한 문서
열람에 대한 기록 및 모니터링 기능 등 시스템적 관리 강화 방안을 마련하여 운영
하시기 바랍니다. (권고)

㉠㉠㉠㉠㉠㉠처장은 ① 향후 정보처리시스템 개발 과정에서 ‘준공 전 기능
테스트’를 성실히 이행함과 동시에 최종 기능 테스트 절차의 과정이 기록될 수
있도록 업무 관련 담당자에 대한 교육을 시행하시기 바랍니다. (기관주의)

